

Lesson 1

Introduction to information gathering, tools, and ethical standards

Disclaimer

What you will go through in this course, is highly highly niched skills that can make you a highly valuable asset in an organization, or an overnight criminal when things are done without permission, or the right ethical considerations.

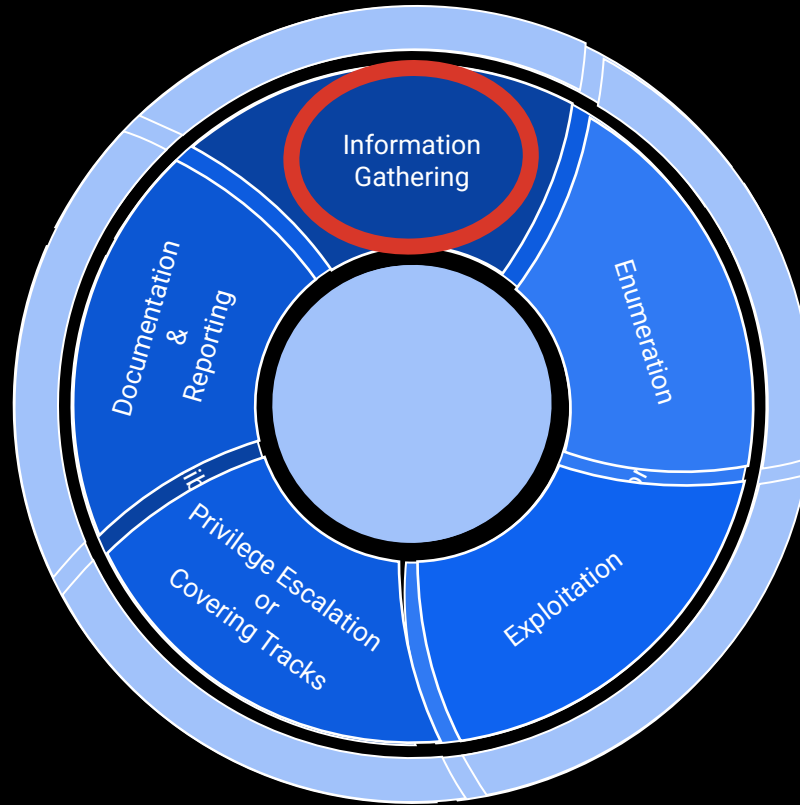
You CAN land in trouble if you breach the computer misuse act, and in no capacity I will be vouching for you, sanctioning you, or even allowing you to attack on properties that are not own by me, or for lesson purpose.

So please, help me to help you by not doing anything taught in class, onto someone else.

What is Penetration Test?

1. Simulated Attack A penetration test is a safe, authorized attempt to break into systems, just like a real hacker would.
2. Find Weaknesses It helps uncover security flaws misconfigurations, unpatched software, and misconfigurations before attackers can exploit them.
3. Real-World Thinking It goes beyond tools and automated scanning. Think creatively and use real attack techniques to test your target.
4. Actionable Results You will produce a report showing what was vulnerable, how it was exploited, and recommendations.

Penetration Testing Life Cycle



Information Gathering

There are mainly two types of information gathering:

- Passive
- Active

Passive Information Gathering (PIG)

The act of gathering information through indirect access of information:

- Open Source Intel (OSINT)
- Google Search
- Government Bulletins
- Dark Web Leaks

By and large, just using forms of non-contact information gathering

Open Source Intel (OSINT)

Widely used as a term to describe means of acquiring information through open source intel platforms.

Examples:

<https://www.shodan.io/> (Device search engine)

<https://opendata.rapid7.com/> (DNS record Database Archive)

<https://toolbox.googleapps.com/apps/dig/>

<https://dnsdumpster.com/>

https://www.shodan.io/ Device search engine

 SHODAN

Explore

Pricing 

smu.edu.sg



Login

TOTAL RESULTS

3

 View Report

 View on Map

 Advanced Search

Product Spotlight: We've Launched a new API for Fast Vulnerability Lookups. Check out [CVEDB](#)

Object moved 

202.161.44.97

intranet.smu.edu.sg

Singapore Management University

 Singapore, Singapore

 **SSL Certificate**

Issued By:

[-] Common Name:
Entrust OV TLS Issuing RSA CA 1

[-] Organization:
SSL Corporation

Issued To:

[-] Common Name:
*intranet.smu.edu.sg

[-] Organization:
SMU

Supported SSL Versions:
TLSv1.2, TLSv1.3

HTTP/1.1 301 Moved Permanently

Content-Type: text/html; charset=utf-8

Location: https://encoreqa.intranet.smu.edu.sg/

X-XSS-Protection: 1; mode=block

Content-Security-Policy: default-src https: data: 'unsafe-inline' 'unsafe-eval'

X-Frame-Options: ALLOW-FROM https://localhost:44330/

Content-...

2025-07-01T16:16:46.848802

SMU Integrated Student Info System Sign-in 

202.161.41.211

eservices.smu.edu.sg

admissions.eservices.smu.edu.sg

Singapore Management University

 Singapore, Singapore

 **SSL Certificate**

Issued By:

[-] Common Name:
Entrust OV TLS Issuing RSA CA 1

[-] Organization:
SSL Corporation

Issued To:

[-] Common Name:
*eservices.smu.edu.sg

[-] Organization:
SMU

Supported SSL Versions:
TLSv1.2, TLSv1.3

HTTP/1.1 200 OK

Cache-Control: no-cache

Cache-Control: no-store

Date: Thu, 26 Jun 2025 09:11:25 GMT

Content-Length: 12812

Content-Type: text/html; CHARSET=utf-8

Expires: Thu, 01 Dec 1994 16:00:00 GMT

Origin-Agent-Cluster: 70

X-ORACLE-QMS-RID: 0

Set-Cookie: STMSPW21-0002-PORTAL-PSJSESSION...

2025-06-26T09:11:26.146440

302 Found 

202.161.41.208

lis.smu.edu.sg

Singapore Management University

 **SSL Certificate**

Issued By:

[-] Common Name:
Entrust OV TLS Issuing RSA CA 1

[-] Organization:
SSL Corporation

Issued To:

[-] Common Name:
*lis.smu.edu.sg

[-] Organization:
SMU

Supported SSL Versions:
TLSv1.2, TLSv1.3

HTTP/1.1 302 Found

Date: Mon, 07 Jul 2025 22:04:44 GMT

Content-Type: text/html; charset=utf-8

Content-Security-Policy: default-src https: data: 'unsafe-inline' 'unsafe-eval'

X-Frame-Options: DENY

2025-07-07T22:04:45.853837

https://opendata.rapid7.com/ (DNS record search engine)

Rapid7 Labs

Forward DNS (FDNS)

< See All Datasets

2,872

LAST UPDATED: 07/13/2025

DNS 'ANY', 'A', 'AAAA', 'TXT', 'MX', and 'CNAME' responses for known forward DNS names

Study Details

Study

Forward DNS (FDNS)

Author

Project Sonar | Rapid7

Contact

Rapid7 Labs

Dataset Details

This dataset contains the responses to DNS requests for all forward DNS names known by Rapid7's Project Sonar. Until early November 2017, all of these were for the 'ANY' record with a fallback A and AAAA request if necessary. After that, the ANY study represents only the responses to ANY requests, and dedicated studies were created for the A, AAAA, CNAME and TXT record lookups with appropriately named files. The file is a GZIP compressed file containing the name, type, value and timestamp of any returned records for a given name in JSON format.

Dataset Schema

Full Dataset Listing

Existing Open Data users can [sign in](#) for access. See the [About page](#) for information on requesting access.

File Name	SHA1-Fingerprint	Size	Updated At
2025-07-12-1752347008-fdns_mx.json.gz	f2b6cc3e92f31ca975949bbd226f7ae5a44949b0	4.0 GB	July 13, 2025

This site uses cookies for anonymized analytics. For more information or to change your cookie settings, view our [Cookie Policy](#).

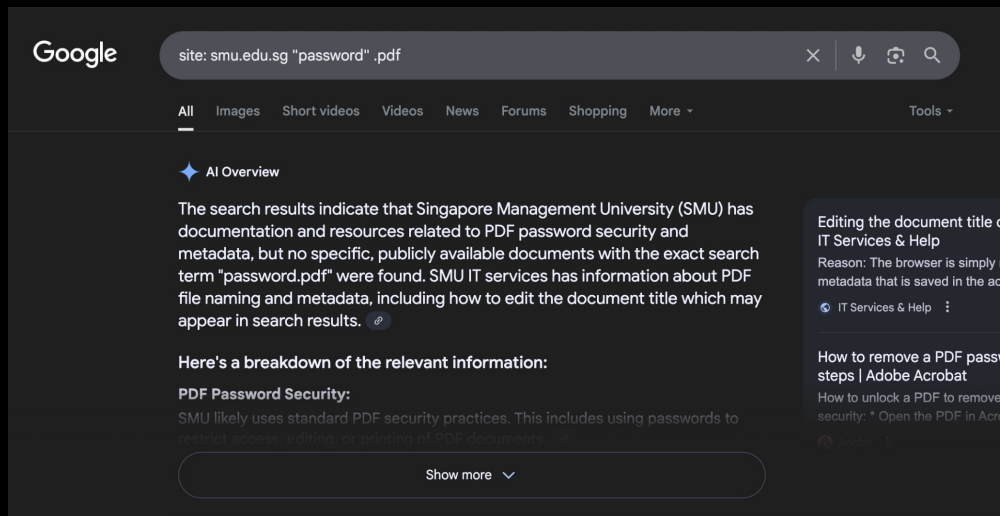
X

Google Searches

As security practitioners, Google is not just our best friend, but number one tool.

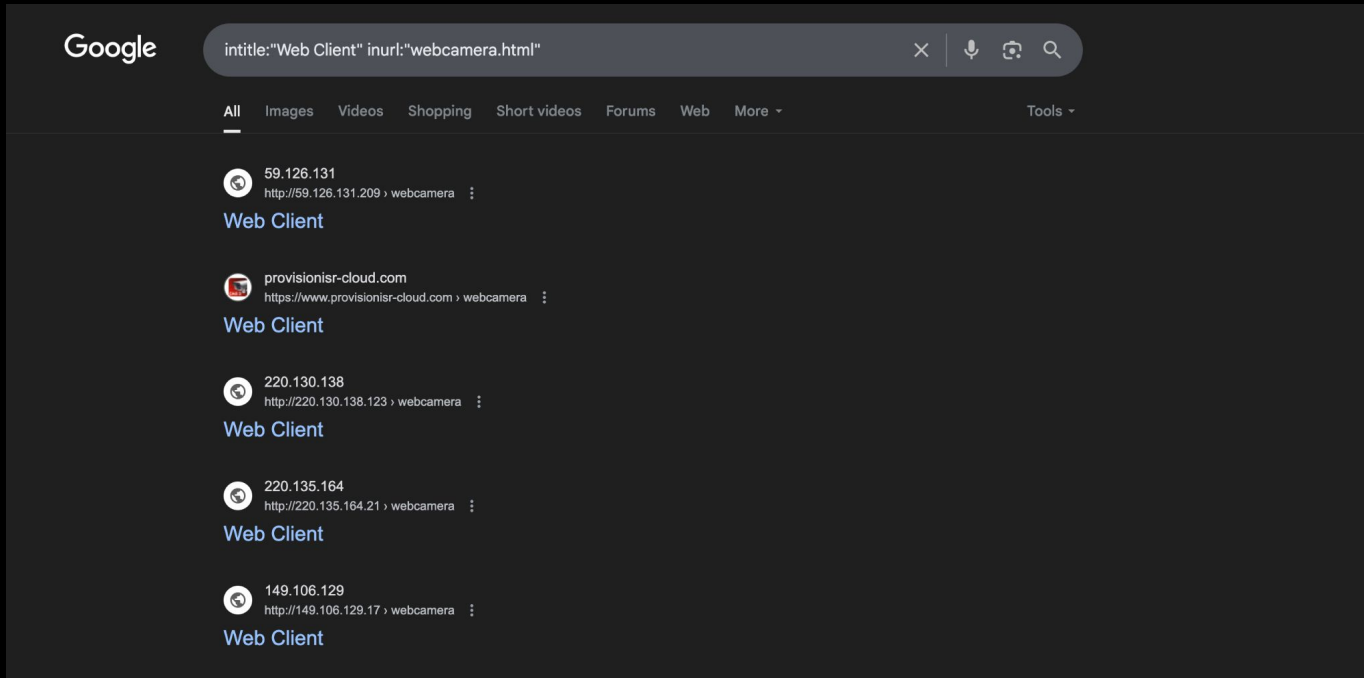
<https://gist.github.com/sundowndev/283efaddbcf896ab405488330d1bbc06>

<https://www.exploit-db.com/google-hacking-database>



Google Searches

You can even find exposed cameras using google search:



Government Bulletins

Sometimes, you can find information about someone through Government services.

Is that person married?

Does that person own a business?

From the info you gathered, branch out to more sources and eventually Googling it all over again.

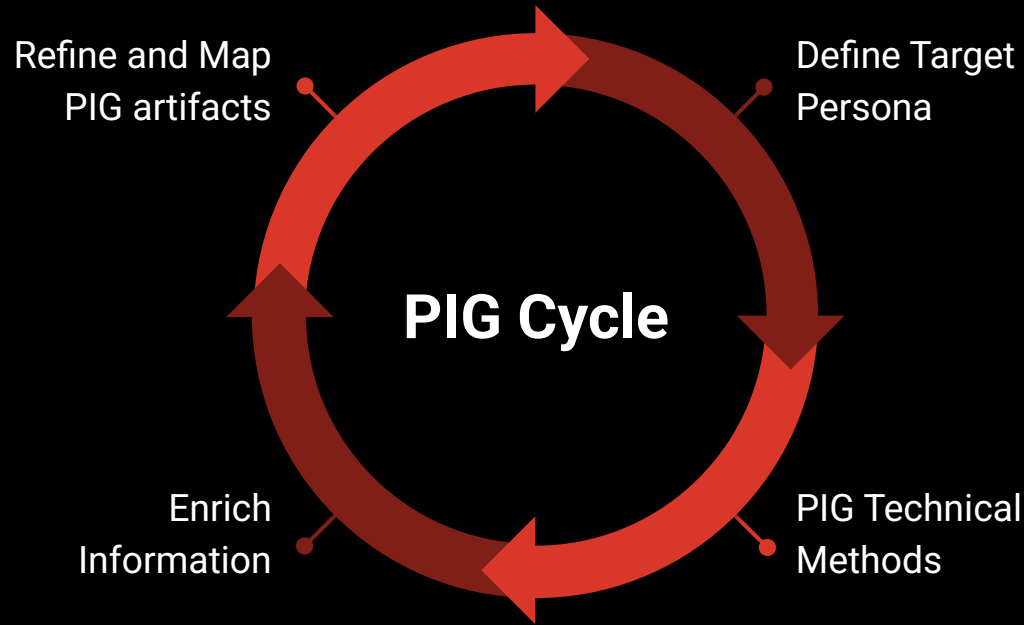
Dark Web Leaks

This is one of the best place to get information about your target. Because if it exists here, it means your target has been breached and/or loopholes exists.

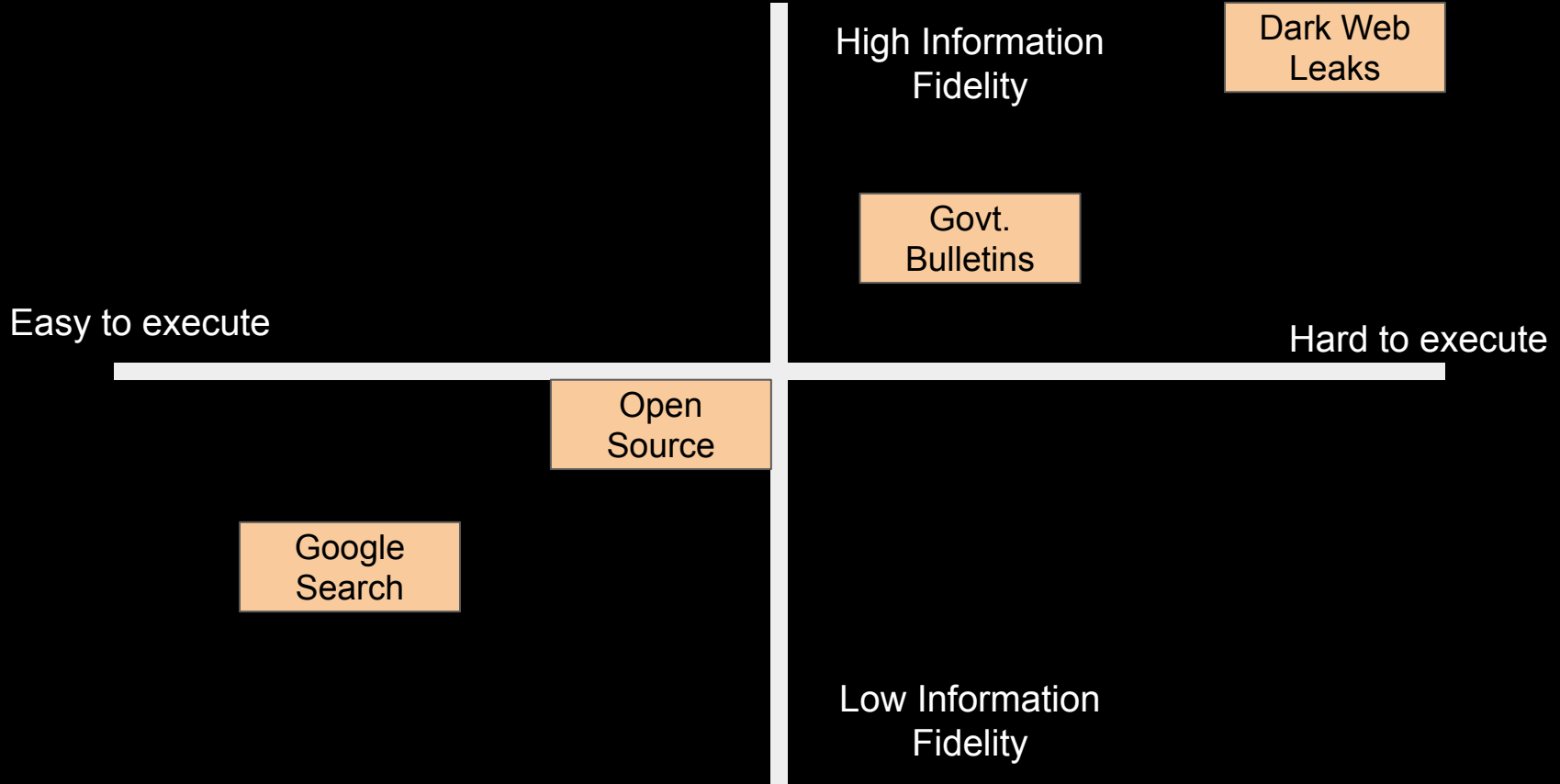
Traditional but might not work anymore: Breach Forums/Raid Forums

Other methods of access: TOR (The Onion Router) network sites [Hard to find]

Passive Information Gathering Cycle



Passive Information Gathering Quadrants



Example

You google searched a website called example123.com

You found that it has login.example123.com

By exploring the page, you view source of the HTML and found an embedded javascript function that does a XHR call to secret.example123.com, using the username admin@example123.com as a payload

You begin to search for admin@example123.com on the internet, and found leaked password on the dark web. You then use that password on the secret web page. Win.

Not all the time...

PIG is not the silver bullet to information gathering. You can never find high fidelity information through PIG.

This is because, “Ghosts” exists, and not everyone has a **high internet footprint**

As such, you need to transition into Active Information Gathering (AIG)

Active Information Gathering

The act of gathering information through direct access of information from target:

- Social Engineering
- Deliberate close-ins (Close contact with target to gather information)
- Drive-by attacks (WiFi scanning, Bluetooth Scanning) - Called war-driving in earlier days
- Physical security parameter canvassing

Social Engineering (S.E.)

The art of social engineering is beyond technical practices, but the art behind human behavioral science and target profiling

- Target profiling is both art and science
- Know your enemy more than you know yourself - Sun Tzu
- Types of S.E.
 - Email phishing
 - Vishing
 - Smishing
 - Ads based S.E.
 - Content based S.E.

Email Phishing

[PayPal]: Your account access has been limited

Team Support services@paypal-accounts.com
to me



Dear PayPal customer,

Your PayPal account is limited, You have 24 hours to solve the problem or your account will be permanently disabled.

We are sorry to inform you that you no longer have access to PayPal's advantages like purchasing, and sending and receiving money.

Why is my PayPal account limited?

We believe that your account is in danger from unauthorized users.

What can I do to resolve the problem?

You have to confirm all of your account details on our secured server by clicking the link below and following the steps.

[Confirm Your Information](#)

Email Phishing

Involves the employment of resources to execute email phishing to gather clicks.
Think of it as email-marketing for bad actors.

Can be done through various ways:

Email Marketing Cloud Service Provider

AWS SES

Mis-configured email servers

Domain takeover email phishing

Domain squatting

Deliberate close-ins

The act of deliberate close-ins brings about greater risk of discovery of attack by the target, and transits the modes from interaction to more active approaches

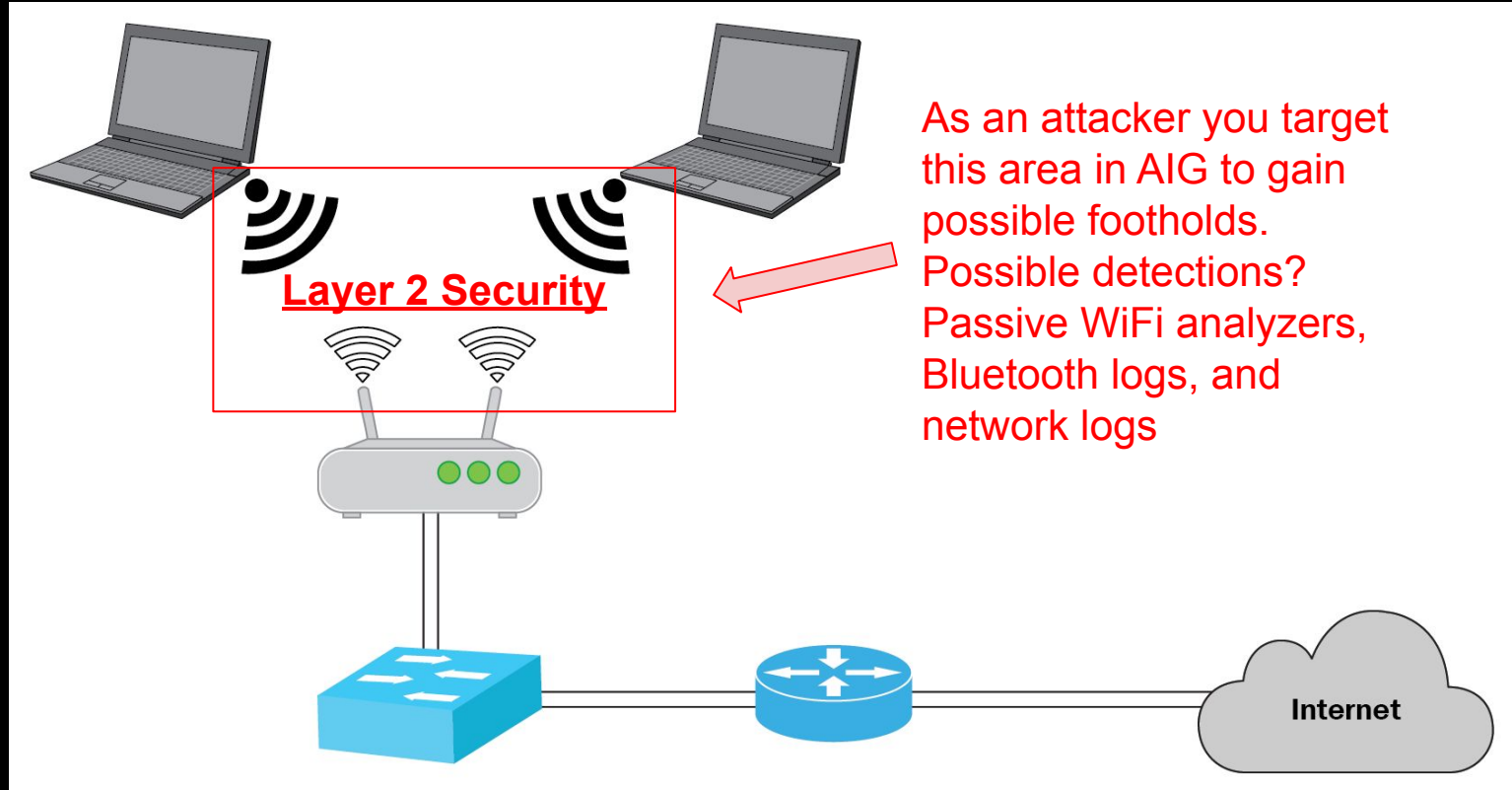
- Shoulder Surfing
- USB attacks
- Exploration of Open source projects with deliberate interactions
- Submission of S.E. oriented communication to targets in deliberate attempts to gain secondary information

Drive By Attacks

WiFi or Bluetooth wardriving focus on:

- Discovering weak security configuration on wireless devices/networks
- Discover loopholes for next phase of attacks, allowing wireless based attacks
- Discovery of Wireless passwords through attacks like WiFi evil twin, WPA2 based attacks, WEP attacks, Pin attacks, and Pixie Dust Attack.
- Discovery of weak Bluetooth devices that can be coerced to send pairing info, or plaintext data. (Medical devices, PMDs, smart devices and many others)
- Perfect target in a smart office/home environment

Drive By Attacks

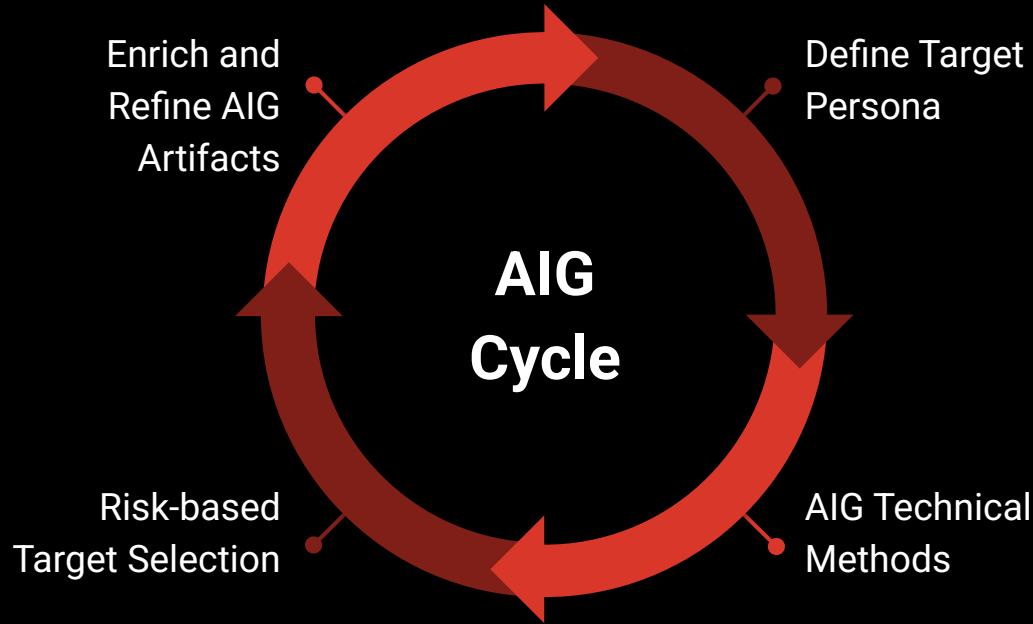


Physical security parameter canvassing

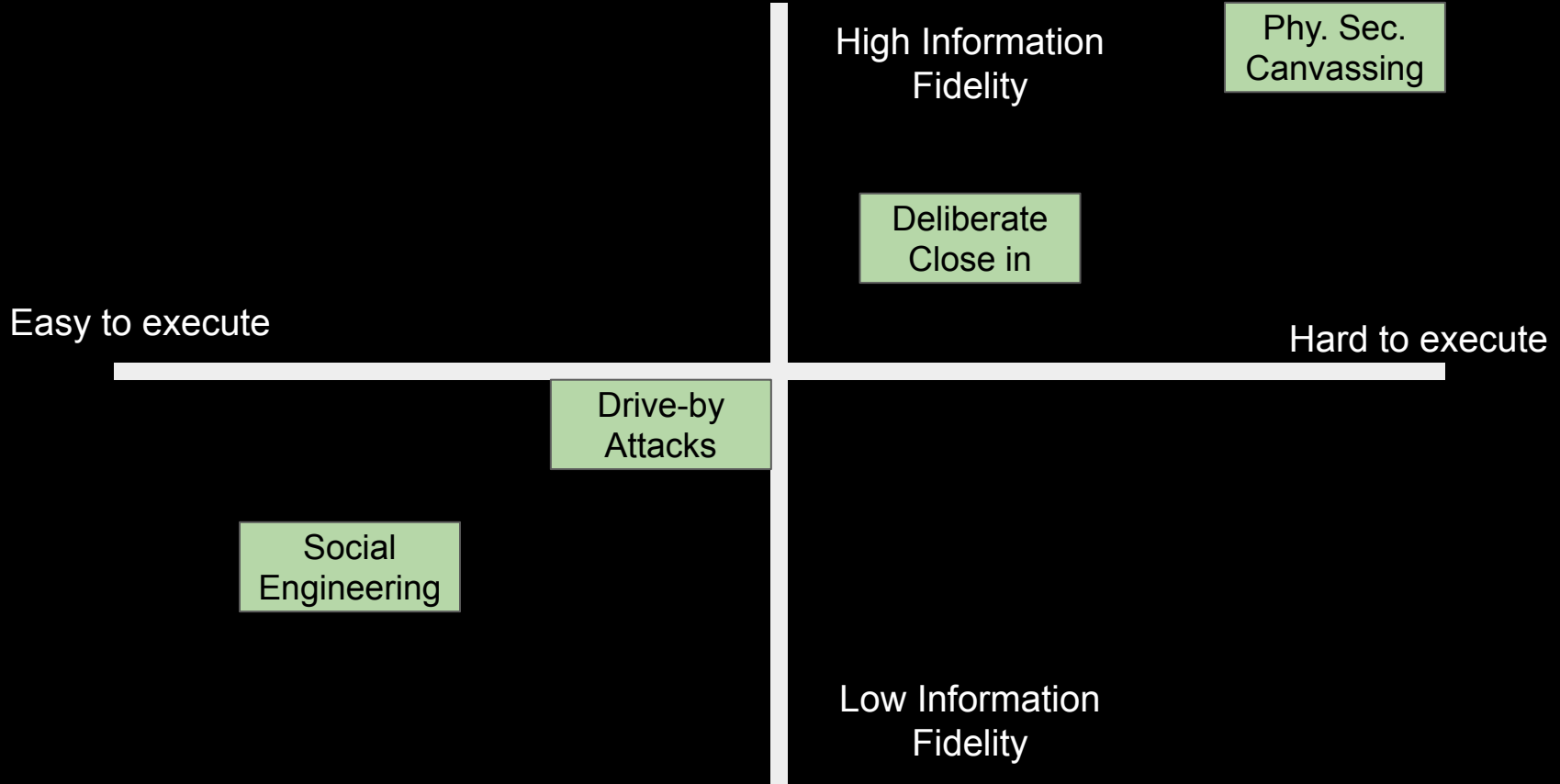
High risk AIG, involving direct interaction with target physical premise.

- Instant camera interaction
- Requires disguise/dress ups
- Highest fidelity of information, including visual and audio confirmation
- Encompasses multiple AIG techniques
- Identification of lock type, digital lock models, network trunking, power and service duct access

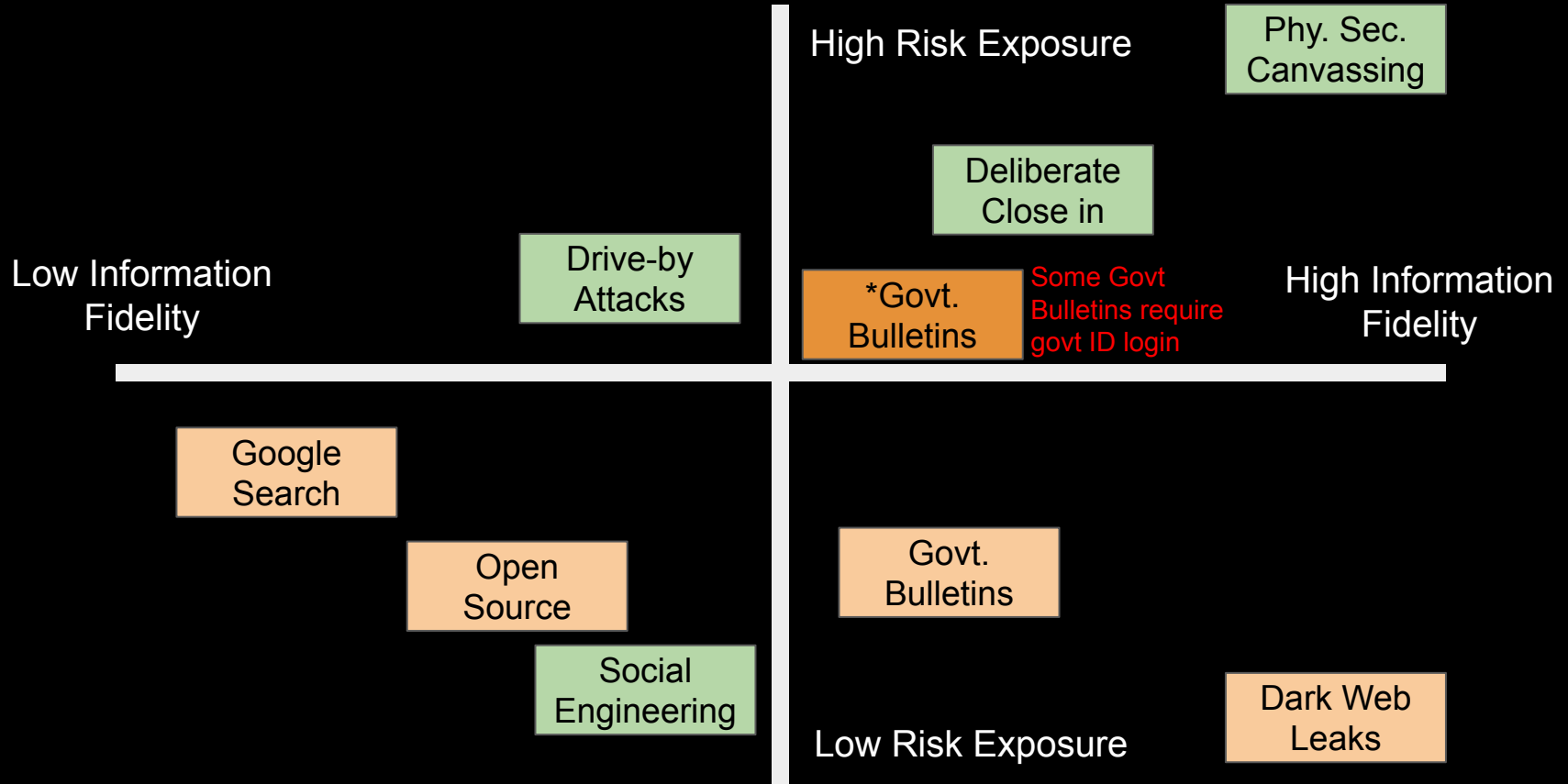
Active Information Gathering Cycle



Active Information Gathering Quadrants



Information Gathering Quadrants



Why is Information Gathering important?

“The Borrowing Arrows with Straw Boats”

If you do not have what you need, you use what is available on the internet to get what you need, like how Zhuge Liang borrow arrows from his enemies using straw boats, you borrow information from the internet to achieve your goal.

No operation/engagement should be done without proper intelligence gathering and understanding of target

Open Source Intel (OSINT)

The access to such information allows **Postulation** of infrastructure design, tech stack, and size of company.

Collecting sufficient information from OSINT can allow the formation of **Predictions**.

Postulations are assumptions based on pure guess and reasonable approximates

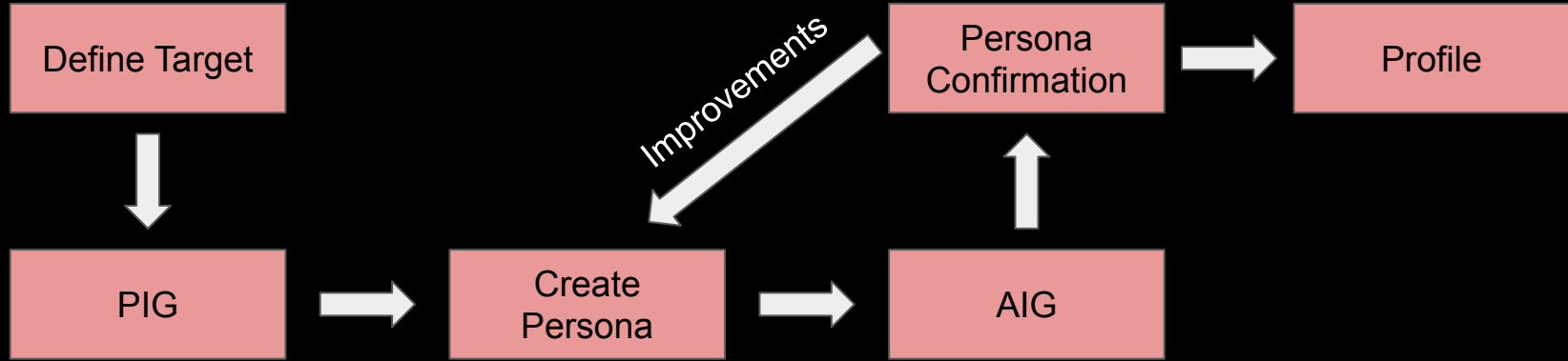
Predictions are assumptions based on facts presented and calculated approximates

Why Postulate before Prediction?

In Offensive Cybersecurity, we assume worst case.

Assumption of worst case allows conservative guesses and risk-based approach on information gathering

Information Gathering Workflow



Break Time

Ethical Standards

In ALL Cybersecurity engagements, we as professionals are held to high standards of ethical considerations and decisions.

- Privacy
- Integrity
- Compliance
- Impartial Disclosure
- Confidentiality
- Safety

Privacy

Access only the data necessary to perform the task.

Avoid collecting or storing excessive or unrelated information.

Never abuse access to sensitive personal or organizational data.

Understand and uphold data protection laws such as GDPR, PDPA, or HIPAA.

* Do you access a HR database even though you broke into the webapp?

Integrity

We must be truthful in reporting findings, capabilities, and impact.

We should not tamper with or falsify data or system states.

We must preserve the original condition of evidence during penetration testing.

* Should you delete a script that was used for initial access?

Compliance

Laws and regulations (CFAA, GDPR, local cybersecurity laws, CMA).

Organizational policies and industry standards (ISO 27001, NIST frameworks).

Ethical codes from governing bodies.

* If doing an action or technical test in Singapore is legal, what if it's done in another country? Will it be the same?

Impartial Disclosure

Report vulnerabilities in a timely and constructive manner.

Avoid exploiting or leaking vulnerabilities for personal gain.

Disclose only to appropriate stakeholders (e.g., organization's security team, bug bounty programs).

Refrain from “naming and shaming” or politicizing security issues.

* You found out that the organization is being actively exploited, what should you do?

Confidentiality

Also covers: Trade secrets, proprietary code, internal emails, customer data, or incident reports.

You must:

Protect information from unauthorized disclosure.

Honour NDAs, access agreements, and client trust.

Avoid gossip, leaks, or any unintentional data exposure.

* You are working on a project on Bank X, should you talk about it at Coffee Shop during lunch with your colleagues outside?

Safety

Misuse of tools or poor ethical judgment can result in harm (e.g., service disruptions to hospitals or critical infrastructure).

Always consider the human impact of your actions. A crashed system could affect lives, not just business operations.

Prioritize minimizing harm during security testing or incident response.

* You found an exploit that works locally, should you use it in production immediately?

The one and only Compass

If you think it is not right, do not do it

If you are unsure, do not do it

If you are over confident, do not do it

If it is not part of the plan, do not do it

If it is not part of the scope, do not, 100% do not do it

If it is not your property, never do it

Always ask and clarify with system owner, 100% must.

Consequences

If you do not comply:

- You can lose your job
- You get bad reputation
- Your circle of professionals will know instantly
- You will need to rebuild trust, again
- You are likely hard to hire due to ethical concerns
- All else fails, you leave the industry and you start over

So, do not break the trust that was built with hard earn effort.

Activity

- Look for the default password used by TP-Link TAPO cameras
- Use Shodan to explore the list of servers with Flask server headers
- Find other interesting ways to using Google Dorking. Try finding other exposures on google

Assignment 1

Investigate on the internet exposed dhcpd.conf and screenshot three examples

Investigate on the internet exposed proftpd.conf and screenshot examples

Ensure you take note of the URLs you found

Example Screenshots

```
# Sample configuration file for ISC dhcpd
#

# option definitions common to all supported networks...
option domain-name "fugue.com";
option domain-name-servers toccata.fugue.com;

option subnet-mask 255.255.255.224;
default-lease-time 600;
max-lease-time 7200;

subnet 204.254.239.0 netmask 255.255.255.224 {
    range 204.254.239.10 204.254.239.20;
    option broadcast-address 204.254.239.31;
    option routers prelude.fugue.com;
}

# The other subnet that shares this physical network
subnet 204.254.239.32 netmask 255.255.255.224 {
    range dynamic-bootp 204.254.239.10 204.254.239.20;
    option broadcast-address 204.254.239.31;
    option routers snarg.fugue.com;
}

subnet 192.5.5.0 netmask 255.255.255.224 {
    range 192.5.5.26 192.5.5.30;
    option name-servers bb.home.vix.com, gw.home.vix.com;
    option domain-name "vix.com";
    option routers 192.5.5.1;
    option subnet-mask 255.255.255.224;
    option broadcast-address 192.5.5.31;
    default-lease-time 600;
    max-lease-time 7200;
}

# Hosts which require special configuration options can be listed in
# host statements. If no address is specified, the address will be
# allocated dynamically (if possible), but the host-specific information
# will still come from the host declaration.

host passacaglia {
    hardware ethernet 0:0:c0:5d:bd:95;
    filename "vmunix.passacaglia";
    server-name "toccata.fugue.com";
}
```

```
#
# /etc/proftpd/proftpd.conf -- This is a basic ProFTPD configuration file.
# To really apply changes reload proftpd after modifications.
#

# Includes DSO modules
Include /etc/proftpd/modules.conf

# Set off to disable IPv6 support which is annoying on IPv4 only boxes.
UseIPv6 on
# If set on you can experience a longer connection delay in many cases.
IdentLookups off

ServerName "NetVisual"
ServerType standalone
DeferWelcome off

MultilineRFC2228 on
DefaultServer on
ShowSymlinks on

TimeoutNoTransfer 600
TimeoutStalled 600
TimeoutIdle 1200

DisplayLogin welcome.msg
DisplayChdir .message true
ListOptions "-l"

DenyFilter \*.*

# Use this to jail all users in their homes
DefaultRoot ~

# Users require a valid shell listed in /etc/shells to login.
# Use this directive to release that constrain.
RequireValidShell off

# Port 21 is the standard FTP port.
Port 21

# In some cases you have to specify passive ports range to by-pass
# firewall limitations. Ephemeral ports can be used for that, but
# feel free to use a more narrow range.
# PassivePorts 49152 65534

# If your host was NATted, this option is useful in order to
# allow passive tranfers to work. You have to use your public
# address and opening the passive ports used on your firewall as well.
# MasqueradeAddress 1.2.3.4

# This is useful for masquerading address with dynamic IPs:
# refresh any configured MasqueradeAddress directives every 8 hours
<IfModule mod_dynmasq.c>
# DynMasqRefresh 28800
</IfModule>

# To prevent DoS attacks, set the maximum number of child processes
# to 30. If you need to allow more than 30 concurrent connections
```

Additional Readings

<https://www.nullsession.pw/all-your-git-is-mine/>

<https://www.nullsession.pw/seriously/>

<https://www.secjuice.com/the-dark-side-of-osint/>

<https://liferaftlabs.com/blog/osint-analysts-9-mistakes-that-can-sabotage-investigations>